

EXTENDED PROJECT QUALIFICATION / UPDATED DISSERTATION

Can contemporary cybersecurity provide effective security for modern digital life?

An investigation of what security means, how computer, IT, information and cybersecurity divide responsibility, and whether their combined practice can keep pace with modern risk

Nathan Brown-Bennett

Independent updated edition based on the 2020 A-level EPQ

Research current to July 2026

This is a complete standalone dissertation. The original assessed submission is preserved separately and is used only as the historical starting point for the updated research question.

Abstract

Modern societies rely on computers, networks, cloud platforms, connected products and digital information for activities ranging from personal communication to healthcare and national infrastructure. This dependence creates a difficult question: if cyber incidents remain common, can cybersecurity reasonably be described as providing effective security? This dissertation argues that the question cannot be answered by counting attacks or asking whether a system is simply secure or insecure. Security is a managed condition in which unacceptable harm is reduced through proportionate controls, clear responsibility, evidence and recovery. It is neither a permanent technical state nor a guarantee that failure will never occur.

The investigation first separates four overlapping fields. Computer security concentrates on an individual computing system and the data it processes. IT security protects an organisation's technology estate and the services needed to operate it. Information security protects information in any form throughout its lifecycle. Cybersecurity addresses harm created through interconnected digital systems, including effects on people, organisations and physical services. These boundaries are analytical rather than absolute: real incidents move between them, which makes ownership and handoffs as important as specialist expertise.

A structured review of current government, standards, professional and peer-reviewed sources is used to examine threat prevalence, governance, human factors, secure design, automation, artificial intelligence, response and resilience. UK evidence shows both continuing exposure and uneven preparedness. In the Cyber Security Breaches Survey 2025/2026, 43 per cent of businesses identified a breach or attack in the preceding year, while only 30 per cent reported a cyber-risk assessment and 25 per cent had a formal incident-response plan. The National Cyber Security Centre handled 204 nationally significant incidents in 2024-25. These figures show serious risk, but they do not prove that cybersecurity is futile: detection increases reported prevalence, many attempted attacks are prevented, and mature response limits consequence.

The dissertation concludes that contemporary cybersecurity can provide effective security, but only conditionally. It works when security is governed as organisational risk, built into products and services, usable by real people, monitored continuously and prepared for recovery. It fails when organisations purchase isolated controls, transfer responsibility to users, leave ownership unclear or measure success only by the absence of visible incidents. The most defensible goal is therefore not perfect protection, but a demonstrable capacity to prevent avoidable harm, detect change, contain failure and restore trusted operation.

Research question

PRIMARY QUESTION

Can contemporary cybersecurity provide effective security for modern digital life, and how do the responsibilities of computer security, IT security, information security and cybersecurity combine to produce that protection?

Contents

1. Introduction
2. Methodology and evaluation approach
3. What security means
4. The four security fields: scope, responsibility and boundaries
5. Security work: roles, outputs and handoffs
6. The modern threat environment
7. Does cybersecurity work?
8. People, usability and security culture
9. Technical architecture and secure-by-design practice
10. Automation and artificial intelligence
11. Governance, law and ethical limits

- 12. Integrated incident analysis
- 13. Discussion
- 14. Conclusion

References

Appendices

Research integrity statement

This dissertation is an independently produced 2026 investigation developed from the question first considered in my A-level EPQ. It is not presented as the assessed 2020 submission and does not alter that historical record. The new work has a different research question, method, structure, evidence base and conclusion. The original questionnaire is excluded from the evidential argument because its sampling and internal inconsistencies do not support general claims. Where the earlier project suggested a useful theme, that theme has been researched again rather than copied forward as fact.

Claims in this edition are attributed through in-text author-date references and a linked reference list. Statistics are stated with their reporting period and population wherever they materially affect the argument. Official publications are not treated as infallible: their methods, reporting thresholds and limitations are considered in Chapter 2. Industry evidence is used selectively and is not allowed to override more transparent public data merely because it reports a larger number.

Terminology convention

Security terminology is contested and context-dependent. This dissertation therefore uses four working definitions rather than claiming that every standard or employer draws the same boundary. Computer security refers to protection of an individual computing system. IT security refers to protection of an organisation's technology estate and operational services. Information security refers to protection of information in any form and the obligations attached to it. Cybersecurity refers to the management of harm arising through interconnected digital systems, including consequences for people, organisations and physical services. Chapter 4 explains and tests these definitions.

The word breach follows the wording of the source being discussed and does not always mean confirmed loss of data. Attack refers to intentional activity intended to defeat or misuse a system; incident refers to an event requiring assessment or response. Risk is used as a contextual judgement about uncertainty and consequence, not as a synonym for threat or vulnerability. Effective security means a defensible reduction in unacceptable harm, supported by evidence and recovery, rather than the total absence of malicious activity.

Summary of the argument

The dissertation develops one cumulative argument. First, absolute security is not an operationally useful standard for complex and changing systems. Second, the four security fields provide complementary lenses whose value lies in clear ownership and handoffs. Third, contemporary evidence shows substantial exposure but also a persistent gap between available practice and consistent adoption. Fourth, people, technology, governance and suppliers form one security system; transferring responsibility to any single part produces fragile protection. Finally, cybersecurity can be effective when it is continuous, proportionate, usable and designed for recovery. Each chapter supplies a necessary part of that conclusion.

1. Introduction

This chapter establishes the problem, research question, scope and criteria by which the answer will be judged.

1.1 Background

Security has always concerned the protection of valued things from unacceptable harm. A lock protects access to a room; a legal process protects rights and evidence; a safety system limits physical injury. Digital technology changes the objects, scale and speed of protection, but not the underlying need to decide what matters, what could damage it and what response is proportionate. Computers now mediate banking, employment, education, entertainment, transport, healthcare, public administration and personal relationships. The same systems that create convenience also concentrate dependence. A stolen credential can expose years of information; a software defect can be reproduced across thousands of organisations; disruption to a connected service can create consequences outside the computer itself.

Public discussion often responds to this tension with two incompatible claims. The first is that cybersecurity is increasingly important because threats are growing. The second is that cybersecurity must be failing because attacks still occur. Both contain part of the truth, but neither supplies a sound test of effectiveness. Medicine is not ineffective because illness exists, and fire safety is not worthless because buildings can burn. A protective discipline must instead be judged against its purpose: whether it reduces foreseeable harm, makes failure less likely, discovers problems early, limits their consequence and supports recovery.

The terminology also creates confusion. Computer security, IT security, information security and cybersecurity are frequently used as synonyms. Standards themselves contain overlapping definitions, and job titles vary between employers. However, the terms draw attention to different protected objects and different decisions. A security engineer hardening an operating system, an identity administrator controlling staff access, an information-security manager assessing regulatory impact and an incident responder containing malicious activity may all contribute to the same event without performing the same work. Treating every task as generic 'cyber' work hides ownership and encourages gaps between teams.

1.2 Aim and objectives

The aim is to determine whether contemporary cybersecurity can provide effective protection for modern

digital life without relying on an unrealistic promise of perfect security. The investigation has six objectives:

- define security as a risk, control and resilience problem rather than a binary label;
- distinguish computer, IT, information and cybersecurity by what each protects and the decisions each owns;
- identify representative roles, work products and handoffs across those fields;
- evaluate current evidence about threats, breaches, preparedness and recovery;
- examine how human factors, technical design, automation, governance and law affect outcomes; and
- construct a reasoned test for deciding when cybersecurity is effective.

1.3 Scope

The dissertation concentrates on civilian digital security in the United Kingdom while using international standards and research where they provide a stronger conceptual basis. It considers individual computers, organisational IT, information handling, internet-connected products, cloud services and the human and governance systems surrounding them. National military cyber operations, offensive cyber capability and classified intelligence are outside scope except where public sources help explain the broader threat environment.

The phrase 'modern digital life' includes both personal and organisational dependence. The evidence base is stronger for organisations because governments and industry publish survey and incident data at that level. Consumer experience is therefore discussed through product security, identity, privacy and connected-device examples rather than treated as statistically equivalent to business data. The research is current to July 2026; fast-moving figures and guidance will require later review.

1.4 Standard for an answer

An answer of 'yes' cannot mean that every attack is prevented. It must mean that suitable combinations of governance, people, process and technology can measurably reduce risk and consequence when they are properly selected and maintained. An answer of 'no' would require evidence that available practices cannot materially improve those outcomes, or that their cost and complexity make them unusable in the environments they are intended to protect. The conclusion will therefore distinguish the capability of the discipline from the quality of its implementation.

2. Methodology and evaluation approach

The investigation is a structured, critical literature review supported by official statistics and an applied incident analysis.

2.1 Research design

A literature-based method is appropriate because the question concerns the boundaries and effectiveness of several disciplines rather than the behaviour of one product or population. The research combines four types of evidence. Standards and glossaries establish terminology and recognised practices. Government surveys and incident reports describe exposure and preparedness. Peer-reviewed and professional research examines conceptual boundaries and human behaviour. Regulatory and technical guidance shows how responsibility is changing in practice.

Sources were prioritised in the following order: current primary publications from NIST, NCSC, UK government and ENISA; legislation and official implementation guidance; peer-reviewed research with a clear method or durable conceptual contribution; and major industry reports where their datasets add detail not available from public statistics. News articles, vendor marketing pages and unsourced explainers were not used as evidence for central claims. Older research was retained only where it introduced an idea that remains relevant, such as the rational cost of security advice to users.

2.2 Search and selection

Searches covered definitions of computer, information, IT and cybersecurity; security risk and resilience; cyber workforce roles; UK breach prevalence and incident response; secure-by-design engineering; usable security; artificial-intelligence risk; product security regulation; and governance. Sources were checked for publication date, responsible organisation, methodology, scope and whether the claim being used could be traced to the original publication. Where a current webpage summarised a formal standard, the standard itself was preferred.

The NIST glossary illustrates why context matters. It aggregates definitions from different documents rather than declaring a single preferred definition for every term. Some sources use computer security, IT security and cybersecurity as synonyms; other research treats cybersecurity as a wider social and organisational domain. The method therefore does not pretend that one universal taxonomy exists. It constructs working

definitions, states their purpose and tests whether they clarify responsibility.

2.3 Interpreting incident statistics

Breach statistics are not a direct score for defensive effectiveness. An organisation with mature monitoring may identify more attacks than one that cannot see them. Surveys depend on respondent knowledge and willingness to disclose; administrative incident data records only events that reach the reporting body; categories and thresholds change over time. Larger organisations have more assets and may be targeted more often, but they also tend to have stronger detection. Comparisons must therefore consider denominator, period, population, severity and measurement method.

The Cyber Security Breaches Survey 2025/2026 is valuable because it publishes its sampling approach, question bases and statistical-reliability guidance. Its estimate that 43 per cent of businesses identified a breach or attack describes recognised exposure during a twelve-month period; it does not claim that 57 per cent experienced none. Similarly, the NCSC's 204 nationally significant incidents describe cases meeting its threshold and handled during the reporting year, not every UK incident.

2.4 Limitations and ethics

No new participant data was collected. The small questionnaire in the 2020 submission is not reused as evidence because its convenience sample, inconsistent response counts and leading questions cannot support claims about the public. This removes an empirical component but improves the integrity of the updated dissertation. Future work could test the proposed field definitions and responsibility model through interviews with practitioners from security operations, IT, risk, privacy and product teams.

The research discusses defensive concepts and publicly documented threats without providing operational instructions for intrusion. Ethical evaluation is part of the subject rather than an afterthought: security controls can monitor people, restrict access and process sensitive data, so effectiveness must include legality, necessity, proportionality and accountability. A control that reduces one technical risk by creating unjustified surveillance is not automatically a good security outcome.

3. What security means

Security begins with valued assets and unacceptable harm. Controls are useful only in relation to that context.

3.1 From absolute safety to managed risk

In everyday language, secure can imply freedom from danger. That absolute meaning becomes unstable when applied to complex systems. A computer contains hardware, firmware, operating-system components, applications, accounts, networks and external services, each changing over time. Its behaviour depends on administrators, developers, users and suppliers. No finite assessment can prove that every component is free from unknown weakness or that every future attacker will fail.

Operational security is better understood as the managed reduction of unacceptable harm. The process identifies assets, threats, vulnerabilities, likelihood and consequence; selects proportionate controls; and reviews whether residual risk is acceptable. This does not weaken the meaning of security. It makes the claim testable. A hospital and a home media player should not apply identical controls, but both should be able to explain what they protect, which failure matters and why their chosen protection is reasonable.

WORKING DEFINITION

Security is the justified and continuously reviewed reduction of unacceptable harm to valued assets, supported by controls that prevent, detect, contain and recover from failure.

3.2 Assets, threats, vulnerabilities and controls

An asset is anything whose loss, exposure, alteration or unavailability would matter. Assets include devices, data, identities, money, intellectual property, services, reputation, safety and public trust. A threat is a circumstance or actor capable of causing harm. A vulnerability is a weakness that makes that harm possible. Risk combines uncertainty about occurrence with consequence. A control changes the likelihood, impact or detectability of an unwanted event.

This vocabulary prevents category errors. Malware is not itself a risk statement; it is one possible threat mechanism. 'Install antivirus' is not a complete strategy; it is a control whose value depends on coverage, configuration, telemetry, response and the threats under consideration. Likewise, a vulnerability score cannot decide business priority without knowing where the affected component is used, whether it is exposed, what data or service depends on it and what compensating controls exist.

3.3 Security properties

Information-security practice commonly begins with confidentiality, integrity and availability. Confidentiality

limits disclosure to authorised people and processes. Integrity protects accuracy, completeness and authorised change. Availability ensures that authorised users can access information and services when required. The three properties interact: encrypting information may protect confidentiality, but inaccessible keys can destroy availability; unrestricted availability may expose confidentiality; an available service returning manipulated results lacks integrity.

Modern systems require additional properties. Authenticity supports confidence that an identity, message or component is genuine. Accountability links actions to responsible entities through evidence such as logs and approvals. Non-repudiation makes it difficult for a party to deny a relevant action. Privacy concerns appropriate processing of information about people, not merely secrecy. Safety addresses physical injury and environmental harm. Resilience concerns the ability to anticipate, withstand, recover and adapt when disruption occurs. These properties explain why a control can succeed technically while the overall system still fails its users.

3.4 Prevention, detection, response and recovery

Preventive controls reduce the chance that harmful action succeeds: secure configuration, authentication, segmentation, input validation and patching are examples. Detective controls reveal relevant change through logs, monitoring, alerting and reporting. Responsive controls contain harm, preserve evidence, communicate decisions and remove an attacker. Recovery restores trusted operation and incorporates learning. Overinvestment in prevention can create brittle security if detection and recovery are absent.

NIST CSF 2.0 expresses a similar lifecycle through Govern, Identify, Protect, Detect, Respond and Recover. The addition and prominence of Govern matters because technology cannot decide risk appetite, allocate accountability or balance competing obligations. The functions are concurrent rather than a one-off checklist: an organisation continuously learns about dependencies, changes protection and improves its ability to respond.

4. The four security fields

The fields overlap, but each begins from a different protected object and operational boundary.

4.1 Computer security

Computer security protects an individual computing system and the information processed or stored by it. The

system may be a laptop, server, mobile phone, embedded controller or virtual machine. Its boundary includes hardware trust, firmware, boot process, operating system, applications, memory, local storage, device interfaces and local accounts. Typical questions ask whether code can execute without authority, whether one process can interfere with another, whether stored data is protected and whether the system can be restored to a trusted state.

Relevant controls include secure boot, code signing, operating-system hardening, memory protection, application sandboxing, endpoint detection, disk encryption, local firewalling, vulnerability management and controlled administrative privilege. Computer security is narrower than organisational IT security because a device can be well hardened while identities, networks, backups or cloud configuration remain weak. It is also foundational: wider security depends on endpoints behaving predictably.

4.2 IT security

IT security protects the technology estate used to deliver an organisation's operations. It includes endpoints but extends to directories, identities, networks, email, collaboration platforms, business applications, databases, cloud services, backups, service-management processes and supplier connections. The central concern is dependable and controlled operation of technology at organisational scale.

IT-security decisions include how users join and leave, which roles receive access, how systems are configured, how changes are approved, how vulnerabilities are prioritised, what is logged, how backups are protected and how service is restored. The field is closely connected to IT operations. Separation of duties is useful, but an antagonistic boundary between 'IT' and 'security' is counterproductive because secure outcomes depend on routine administration being performed consistently.

4.3 Information security

Information security protects information and its value throughout its lifecycle, regardless of format. A printed contract, spoken medical detail, paper visitor list and encrypted database can all contain information requiring protection. The field asks how information is created, classified, accessed, shared, retained, transformed and destroyed, and which legal, contractual or organisational obligations apply.

Its scope therefore includes policies, risk assessment, classification, records management, supplier assurance, physical handling, business continuity and audit as well as technical controls. Information security provides a durable link between technology and business meaning. A database administrator may know that a table is

encrypted; the information owner must determine whether the data should have been collected, who needs it, how long it should remain and what disclosure would mean.

4.4 Cybersecurity

Cybersecurity addresses harm arising through interconnected digital systems. It includes the protection of technology and information but gives greater attention to adversarial activity, networks, external dependencies, digital services and consequences extending into society or the physical world. Von Solms and van Niekerk argue that cybersecurity extends beyond information security because not all assets in cyberspace are information: people, infrastructure and societal functions may also be harmed.

This broader scope includes threat intelligence, security operations, incident coordination, online fraud, connected-product security, operational technology and national resilience. Cybersecurity does not replace the other fields. It connects them when the source or path of harm is digital and networked. For example, ransomware involves endpoint behaviour, IT-wide identity and backup decisions, information impact, business continuity, law enforcement and sometimes physical service disruption.

4.5 Adjacent fields

Privacy, data protection, physical security, safety, fraud, resilience and digital forensics intersect with the four fields. Privacy asks whether personal information is processed fairly and appropriately; security supplies some protections but cannot establish lawful purpose by itself. Safety concentrates on preventing injury, which can conflict with confidentiality or access restrictions during emergencies. Fraud teams focus on deceptive transactions and financial loss. Digital forensics preserves and analyses evidence. These domains should coordinate without being collapsed into one undefined security function.

4.6 Where the boundaries overlap

The four-field model is best understood as a set of lenses. Computer security asks whether a device can be trusted. IT security asks whether the technology estate is controlled and dependable. Information security asks whether information and obligations are protected. Cybersecurity asks how connected digital activity can cause wider harm and how that activity should be anticipated and answered. A mature organisation applies all four questions to important systems.

BOUNDARY PRINCIPLE

Labels should clarify ownership, expertise and handoffs. They become harmful when they create silos or allow one team to assume that another has accepted a risk.

5. Security work: roles, outputs and handoffs

Job titles are inconsistent; work is better understood through responsibilities, decisions and evidence.

5.1 Why roles are difficult to classify

A 'security engineer' may design cloud controls in one organisation, manage endpoint tools in another and test applications in a third. A systems administrator may perform security-critical work without holding a security title. The NICE Workforce Framework addresses this problem by describing work roles through tasks, knowledge and skills rather than assuming that job titles are universal. Its current components provide a common language for workforce planning while recognising that one job can combine several roles and that work roles are not identical to positions.

5.2 Roles centred on computer security

Endpoint-security engineers, platform-security engineers, operating-system specialists, malware analysts and vulnerability researchers concentrate on the behaviour of individual systems. Their outputs include hardened baselines, secure-build configurations, endpoint policies, vulnerability findings, exploitability assessments, malware reports and evidence that a device can be rebuilt or recovered. Software-security engineers and application-security testers overlap when the protected computer hosts code they evaluate.

These roles need deep technical access but should not decide business consequence alone. A critical vulnerability on an isolated laboratory device may be less urgent than a moderate weakness on an internet-facing identity server. Computer-security evidence must be handed to IT owners and risk owners who understand exposure, dependency and operational impact.

5.3 Roles centred on IT security

Security administrators, identity and access specialists, network-security engineers, cloud-security engineers, vulnerability managers, backup specialists and security operations analysts protect the organisational estate. They operate access reviews, segmentation, configuration standards, patch programmes, monitoring platforms,

email controls, secrets management and recovery systems. Their outputs include inventories, access records, change evidence, alert rules, remediation plans and service-recovery tests.

IT-security roles work closest to routine operations. That position gives them practical knowledge of technical debt, maintenance windows, supplier constraints and user needs, but can also create conflicts between availability and change. Governance must establish how urgent risk decisions are escalated so that administrators are not forced to accept business risk informally.

5.4 Roles centred on information security

Information-security managers, risk analysts, governance and compliance specialists, security architects, auditors and information owners translate organisational obligations into requirements. Their work includes risk registers, policies, control frameworks, classification schemes, supplier assessments, assurance reviews, continuity requirements and reports to leadership. Data-protection professionals overlap but retain a distinct focus on lawful and fair processing of personal information.

These roles can fail if governance becomes documentation detached from operations. A policy stating that access is reviewed annually has little value if the identity system cannot produce reliable membership data. Effective information security therefore asks for evidence from technical teams and tests whether the control changes real exposure, not merely whether a document exists.

5.5 Roles centred on cybersecurity

SOC analysts, threat hunters, incident responders, threat-intelligence analysts, penetration testers, digital-forensics specialists, cybercrime investigators and operational-technology security engineers focus on adversarial activity and connected harm. Their outputs include alerts, incident timelines, containment actions, intelligence assessments, attack-path findings, forensic images, lessons learned and coordinated communications.

Incident response is inherently cross-functional. Responders may need authority to isolate devices, reset identities, interrupt services, preserve evidence, notify regulators, contact suppliers and communicate with affected people. Technical competence without pre-agreed decision rights creates delay at the moment when delay is most costly.

5.6 Leadership and shared responsibility

Boards and senior leaders own organisational risk even when specialists manage controls. Product managers and

developers own design decisions; procurement teams influence supplier exposure; HR manages joining, movement and leaving; legal teams interpret obligations; communications teams manage public information; and every user operates within the system. 'Security is everyone's responsibility' is useful only if it does not erase accountable owners. Shared participation must sit beneath named decision authority.

A good handoff records the asset, event, evidence, uncertainty, owner, decision and deadline. For example, a vulnerability analyst establishes technical exposure; the service owner explains operational context; the information owner describes affected data; the risk owner accepts, transfers, mitigates or avoids the risk; and assurance checks completion. Each participant contributes a different fact. None should assume that forwarding a ticket transfers accountability.

6. The modern threat environment

Digital dependence, concentrated suppliers and automation have increased both opportunity and consequence.

6.1 Dependence and attack surface

The attack surface of a modern organisation includes devices, web applications, APIs, identity providers, cloud platforms, remote-access paths, mobile applications, connected products, operational technology and suppliers. A small organisation may own little infrastructure yet depend on dozens of software services. This can improve security when specialist providers operate stronger controls, but it also concentrates risk: one identity, software or supply-chain failure may affect many customers.

ENISA's Threat Landscape 2025 analysed 4,875 incidents observed between July 2024 and June 2025. The dataset should not be read as a complete census, but it demonstrates the diversity of threats affecting availability, data, public administration, transport, manufacturing and other sectors. The NCSC reported 429 incidents handled in 2024-25, including 204 classified as nationally significant and 18 as highly significant. The nationally significant total was more than double the previous year's 89.

6.2 Threat actors and motives

Threat actors include financially motivated criminals, hostile states, ideological groups, insiders, competitors and opportunistic individuals. Their capability and patience differ. Criminal groups seek payment, saleable data or fraudulent transactions. States may pursue

intelligence, disruption or strategic access. Insiders may act maliciously, under coercion or through error. The same vulnerability can therefore create different risk depending on who can reach it and what outcome they seek.

Attribution is uncertain and rarely necessary for the first defensive decision. An organisation must contain malicious access before it knows the actor's identity. Threat intelligence is valuable when it changes a decision about exposure, detection or response; collections of indicators without context can consume attention without reducing risk.

6.3 Common paths to harm

Phishing and social engineering exploit trust, urgency and familiar communication. Credential theft turns legitimate access mechanisms against their owners. Exploitation of internet-facing vulnerabilities targets unpatched or misconfigured services. Malware and ransomware automate disruption and extortion. Supply-chain compromise reaches targets through trusted software or service providers. Cloud incidents often involve identity, permissions or exposed data rather than a failure of the underlying provider.

Connected products add long support lifecycles, weak update mechanisms, default credentials and physical effects. Operational technology can prioritise availability and safety over rapid change, making ordinary IT patching assumptions unsuitable. Mobile and home working blur the network boundary. These examples support an identity- and asset-centred model: organisations must know what they depend on and continuously verify access rather than assume that location alone creates trust.

6.4 Consequence, not novelty

Security discussion is easily distracted by novel tools and dramatic attack names. Many serious incidents still use familiar weaknesses: missing multi-factor authentication, excessive privilege, unpatched systems, weak recovery, exposed secrets or delayed detection. Novel capability matters, especially where AI improves scale, but consequence depends on ordinary architecture and preparedness. A convincing message becomes catastrophic only when one credential can reach critical assets and the organisation cannot detect, contain or recover.

7. Does cybersecurity work?

Effectiveness must be assessed through avoided harm, controlled consequence and quality of recovery—not the mere existence of attacks.

7.1 What current UK evidence shows

The Cyber Security Breaches Survey 2025/2026 estimates that 43 per cent of UK businesses and 28 per cent of charities identified a breach or attack in the previous twelve months. Prevalence was higher among medium and large businesses. Phishing remained the most common type identified. The survey also reported increases in the proportions of affected businesses associating their most disruptive incident with revenue or share-value loss and reputational damage, although the absolute percentages remained small.

Preparedness was uneven. Fifty-two per cent of businesses had undertaken at least one listed activity to identify cyber risks, but only 30 per cent reported a cyber-risk assessment, 18 per cent a vulnerability audit and 13 per cent penetration testing. Thirty-one per cent assigned explicit board responsibility and 25 per cent had a formal incident-response plan. Forty-five per cent reported none of the listed response measures. Appropriate action varies by risk, but the gap indicates that many organisations depend on digital systems without a structured understanding of failure.

EVIDENCE SUMMARY

High attack prevalence demonstrates exposure. Low adoption of risk assessment and response planning demonstrates an implementation gap. Neither finding shows that established security practice is incapable of reducing harm.

7.2 Why breaches do not equal total failure

An attempted phishing message counted as an identified attack may be blocked, reported or contained without material harm. Conversely, an organisation that reports no attacks may lack visibility. Success often appears as an event that did not escalate: a stolen password rejected by multi-factor authentication, malicious code isolated by endpoint controls, unauthorised privilege detected in logs or data restored from protected backups. These counterfactual outcomes are difficult to aggregate but central to assessing value.

The appropriate unit of analysis is therefore not simply 'breached or not breached'. Measures should include control coverage, time to detect, time to contain, scope of access, data affected, service interruption, recovery against objectives, recurrence and the quality of learning. Metrics can themselves distort behaviour: a team rewarded for fewer incidents may discourage reporting, while a team rewarded for closing vulnerabilities may prioritise easy counts over important exposure.

7.3 Evidence that controls matter

Security controls are not equally effective in every context, but layered protection changes attacker cost and consequence. Phishing-resistant authentication reduces the value of reusable passwords. Least privilege limits what a compromised account can reach. Segmentation restricts movement. Secure updates remove known weaknesses. Logging and detection shorten the period of unnoticed access. Offline or logically protected backups make destructive extortion less powerful. Rehearsed response improves the speed and confidence of containment.

The defence-in-depth principle recognises that each control can fail. Its value depends on independence and coverage, not the number of products purchased. Five tools relying on the same identity and telemetry may share one failure. Effective layering combines prevention, detection and recovery across technical and organisational boundaries.

7.4 The implementation gap

The strongest criticism of contemporary cybersecurity is not absence of knowledge but inconsistent execution. Organisations may not know their assets, maintain unsupported systems, grant excessive access, retain unnecessary data, fail to test backups or leave suppliers unexamined. Controls may be deployed without owners or tuned so poorly that staff work around them. Security programmes can become compliance theatre when evidence is produced for an audit but operational behaviour does not change.

Resource inequality matters. Large organisations can employ specialists and purchase managed services; small organisations may rely on general IT support. Secure defaults, proportionate guidance and supplier responsibility are therefore essential. A model that works only when every organisation employs a large security team cannot secure an economy composed largely of smaller organisations.

8. People, usability and security culture

People are participants in security systems. Treating them only as weaknesses hides design and organisational causes.

8.1 The problem with 'human error'

Post-incident explanations often end with a person clicking, sharing, misconfiguring or delaying. The description may be factually correct but analytically incomplete. Actions occur inside interfaces, workloads,

incentives, authority structures and technical boundaries designed by organisations. If one ordinary mistake permits catastrophic and irreversible harm, excessive privilege, weak isolation, poor detection or absent recovery also contributed.

Blame can reduce security by discouraging early reporting. A person who fears punishment may hide an error until evidence disappears or harm spreads. A learning culture makes rapid reporting easy, limits access by default and examines why the system allowed the action. This does not remove individual responsibility for deliberate misconduct; it distinguishes accountability from a simplistic search for the last person who touched the system.

8.2 The cost of security advice

Herley's analysis of user security advice argues that precautions impose time and effort on users while many benefits are uncertain or accrue to others. Ignoring advice can therefore be rational from an individual perspective. The lesson is not that users should reject security, but that designers must consider the economic and cognitive cost of controls. Repeated warnings, complex password rules and frequent low-value prompts train people to dismiss interruption.

Usable security makes the safer action the easier and more comprehensible action. Password managers, single sign-on, phishing-resistant authentication, clear permission requests, automatic updates and safe recovery reduce reliance on memory and vigilance. Defaults matter because most users reasonably expect products to work without expert reconfiguration.

8.3 Education and awareness

Education remains necessary. People need to recognise suspicious requests, understand the value of information, know how to report concerns and appreciate why certain controls exist. Training is most effective when relevant to actual work, repeated at sensible intervals and supported by immediate feedback. Generic annual presentations cannot prepare every role for changing attacks.

Awareness is not a substitute for engineering. Training cannot repair unsupported software, remove a default password, limit a cloud permission or create a tested backup. Organisations sometimes overstate the user's duty because behaviour change appears cheaper than redesign. A balanced programme combines education with technical guardrails, clear process and leadership.

8.4 Security culture

Culture is visible in routine decisions: whether deadlines override risk without approval, whether staff

can challenge unusual requests, whether incidents are reported quickly, whether leaders follow the same controls as everyone else and whether security teams understand operational needs. A culture of fear can produce hidden workarounds; a culture of convenience can normalise excessive access. Healthy culture supports constructive challenge and treats security as part of quality.

9. Technical architecture and secure-by-design practice

Technology is effective when controls are designed into systems, maintained as dependencies change and supported by evidence.

9.1 Secure by design and by default

Secure by design moves security decisions earlier in a product or service lifecycle. Teams identify assets and abuse cases, model threats, choose trust boundaries, minimise privilege, validate input, protect secrets, log relevant events and plan updates before deployment. Secure by default means the product begins in a defensible state without requiring specialist knowledge from every customer.

NCSC software-security guidance asks organisations to establish ownership, threat-model throughout development, prevent common weaknesses, protect development environments and manage vulnerabilities. CISA's secure-by-design campaign similarly argues that customer security should be a core business requirement. This changes the distribution of responsibility: a manufacturer is better placed than each customer to remove a default weakness affecting every installation.

9.2 Identity and access

Identity has become a primary security boundary in cloud and hybrid environments. Strong authentication must be combined with lifecycle management, least privilege, separation of duties, review of dormant accounts and protection of administrative access. Multi-factor authentication reduces risk but methods differ; phishing-resistant approaches provide stronger protection than codes that can be relayed.

Zero-trust principles are often reduced to a product label. Their practical value lies in removing implicit trust based only on network location, verifying access in context, minimising privilege and assuming that compromise can occur. Continuous verification should not mean constant obstruction. Signals and policy must be reliable enough that users can perform legitimate work.

9.3 Vulnerability and configuration management

Known vulnerabilities create avoidable risk when exposed systems remain unpatched, but patching is not a single metric. Organisations need an inventory, supplier information, exposure context, tested deployment and exception handling. Configuration weaknesses—public storage, unnecessary services, excessive permissions and unmanaged secrets—can be as important as software defects. Baselines and automated checks help teams detect drift.

Prioritisation should combine technical severity with exploitation evidence, reachability, asset value and available mitigations. Treating every finding as equally urgent overwhelms teams and reduces attention to the attack paths most likely to create serious consequence.

9.4 Monitoring and detection

Logs provide evidence only when relevant events are generated, protected, retained and reviewed. A security operations centre may combine endpoint, identity, network, application and cloud telemetry to identify behaviour inconsistent with expected use. Detection engineering converts threat hypotheses into testable signals. Too many low-quality alerts create fatigue and hide important events.

Monitoring must also respect privacy and employment law. Collecting every possible event can increase risk, cost and intrusion without improving decisions. Purpose, access, retention and oversight should be defined. The aim is sufficient evidence for prevention, investigation and learning—not surveillance as an end in itself.

9.5 Response, continuity and recovery

Incident response requires prepared roles, communication routes, technical access and decision authority. Plans should cover triage, containment, evidence, legal assessment, supplier contact, affected people, service restoration and public communication. Exercises expose missing permissions and assumptions before a crisis. A plan that has never been tested remains a hypothesis.

Backups are useful only when recoverable, sufficiently recent and protected from the same compromise as the primary system. Recovery objectives should reflect operational need. Restoring service without understanding the cause may reintroduce an attacker; delaying restoration indefinitely can create greater harm. Resilience balances trusted recovery with continuity of essential functions.

9.6 Connected-product security

Consumer connected products historically placed substantial responsibility on purchasers who could not evaluate update policy, vulnerability handling or hidden dependencies. The UK's Product Security and Telecommunications Infrastructure product-security regime, effective from 29 April 2024, introduced minimum obligations for relevant consumer connectable products, including requirements associated with passwords, vulnerability reporting and transparency about security updates.

Regulation does not make every product secure, but it changes the baseline and creates accountable obligations upstream. Procurement and provisioning still matter: organisations should understand support periods, network requirements, data flows, ownership, update mechanisms and secure configuration before deployment. This is where security research can become a practical decision tool rather than general advice.

10. Automation and artificial intelligence

Automation is required for scale, but it inherits assumptions and cannot own consequence.

10.1 Defensive automation

Modern estates produce more events, assets and configuration changes than people can inspect manually. Automation supports asset discovery, software inventory, configuration checking, vulnerability scanning, log correlation, malware analysis, alert enrichment and repeatable response. It can reduce delay and variation, particularly for high-volume tasks with clear rules.

Automation also creates failure modes. An incorrect rule can block legitimate service, remove evidence or disable accounts at scale. A detector trained on past behaviour may miss a novel attack or reproduce bias in its data. Safe automation therefore uses bounded authority, testing, audit trails, rollback and human review proportionate to consequence.

10.2 AI for defenders and attackers

Artificial intelligence can assist defenders with summarisation, code review, anomaly identification, triage, query generation and threat-intelligence analysis. Generative systems can make specialist tools more accessible by translating between natural language and technical formats. They may also help smaller teams interpret evidence more quickly.

The same capabilities can help attackers create persuasive content, translate lures, search public information, generate code and automate reconnaissance. AI does not eliminate the need for access, execution and persistence, but it can reduce cost and increase scale. Defensive planning should focus on the resulting attack path rather than assume that every AI-generated artefact is uniquely detectable.

10.3 Securing AI systems

AI systems introduce assets and dependencies of their own: training and retrieval data, model artefacts, prompts, tools, credentials, external APIs, user inputs and generated outputs. Risks include data leakage, poisoning, prompt injection, unsafe tool use, unreliable output and over-trust. Traditional controls such as access management, input handling, logging, change control and incident response remain relevant but must be adapted to probabilistic behaviour.

NIST's AI Risk Management Framework organises work around Govern, Map, Measure and Manage. Its value is the insistence that risk be considered across the lifecycle and in context. An accurate model can still be unsafe if used for a decision it was not designed to support. Accountability must remain with people and organisations able to explain the purpose, evidence and consequence of deployment.

10.4 Will AI replace security professionals?

Some tasks will change or become automated, particularly repetitive analysis and first-pass production. However, security work includes uncertainty, negotiation, ethics, system context and responsibility for consequence. A model cannot accept organisational risk or repair a broken relationship between product, IT and leadership. The more plausible future is collaboration: professionals use AI to extend reach while remaining accountable for validation and decisions.

11. Governance, law and ethical limits

Security becomes effective when technical evidence informs accountable organisational decisions.

11.1 Governance and risk ownership

Cyber risk can affect revenue, safety, legal duties, reputation and the ability to operate. It is therefore an enterprise risk rather than a matter that leadership can delegate completely to an IT team. The UK Cyber Governance Code of Practice sets expectations for boards and directors across risk management, strategy, people,

incident planning and assurance. Its emphasis reflects a basic principle: specialists advise and operate controls, but organisational leaders decide priorities and accept residual risk.

Governance should connect risk appetite to technical work. A board-level statement that disruption is intolerable must become recovery objectives, architecture, investment, supplier requirements and exercises. Reporting should describe exposure, control confidence and consequence rather than present uninterpreted counts. Leadership also needs uncertainty; a falsely precise dashboard can hide weak data.

11.2 Law, regulation and standards

Law establishes minimum duties and remedies, while standards organise good practice. Data-protection law requires appropriate security for personal data but also principles such as purpose limitation and data minimisation. Product-security regulation places obligations on relevant manufacturers and supply-chain businesses. Sector rules may add resilience, reporting or safety duties. Compliance can motivate action, but a control designed only to pass an audit may fail against real threats.

Frameworks such as NIST CSF 2.0 are intentionally adaptable. They describe outcomes rather than prescribe one product set. This supports proportionality but requires judgement. Certification and assurance can increase confidence, yet neither proves that a system is invulnerable or that controls remain effective after change.

11.3 Ethical tensions

Security decisions distribute power. Monitoring can reveal misconduct but also expose personal behaviour. Access controls protect information but may exclude people during urgent need. Automated fraud controls reduce loss but can unfairly deny legitimate users. Vulnerability research can improve products but create risk if disclosure is mishandled. Ethical practice asks who benefits, who bears cost, whose rights are affected and what remedy exists when a control is wrong.

Proportionality provides a useful test. Data collection and restriction should be necessary for a defined purpose, no more intrusive than required, time-limited where appropriate and subject to oversight. Security is not an automatic justification for unlimited surveillance or secrecy. Trustworthy protection includes the ability to challenge decisions and hold powerful actors accountable.

11.4 Inequality and public value

Security burdens fall unevenly. People with limited digital access, time or technical confidence may be least able to navigate complex recovery. Small organisations may lack specialist staff. Victims of abuse face threats from people who know their devices and relationships. Product design and public policy should therefore avoid assuming an expert, well-resourced user. Recovery routes, accessible authentication and safe support are part of effective security.

12. Integrated incident analysis

A stolen cloud credential demonstrates why the four fields must retain distinct questions while operating as one response.

12.1 Scenario

An employee receives a convincing message that imitates a supplier's document-sharing notification. The employee follows the link and completes an authentication flow controlled by an attacker. The attacker uses the resulting session to enter the organisation's cloud environment, searches email and shared storage, creates a persistence mechanism and downloads files containing customer and staff information. Unusual activity is detected several hours later.

The scenario is deliberately ordinary. It does not depend on an unknown vulnerability or extraordinary actor. Its consequence depends on the authentication method, device evidence, account privilege, cloud configuration, information holdings, detection coverage, supplier process and response authority.

12.2 Computer-security perspective

Computer security asks whether the endpoint was compromised, what executed locally, whether browser or credential material remains exposed and whether the system can be trusted. Endpoint logs, process history, browser artefacts, malware scans and memory or disk evidence may be relevant. The endpoint team isolates the device if necessary and determines whether rebuild is safer than continued use.

12.3 IT-security perspective

IT security asks how the identity was authenticated, which permissions it held, what services were reached and whether persistence or forwarding rules remain. Identity administrators revoke sessions, reset credentials, review multi-factor methods, search related sign-ins and remove malicious changes. Cloud and network teams

preserve logs, restrict access and examine whether least privilege and conditional policy worked as intended.

12.4 Information-security perspective

Information security identifies the files accessed, their classification, owners, retention basis and contractual or legal significance. It assesses confidentiality, integrity and availability impact, coordinates with data-protection and legal specialists, and records risk decisions. The analysis may reveal that excessive data retention increased consequence even though the technical entry path was an identity failure.

12.5 Cybersecurity perspective

Cybersecurity connects the event into an adversarial incident. Responders construct a timeline, search for related activity, identify tactics, coordinate containment, assess wider campaigns and communicate with suppliers or authorities where appropriate. Threat intelligence may establish whether the lure belongs to a known campaign, but response should not wait for confident attribution.

12.6 Governance, people and recovery

The incident lead needs authority to make cross-system decisions. Management must balance containment with service continuity and decide notifications. Communications should support affected people without speculation. The employee should be treated as an evidence source and participant, not the complete cause. Review should ask why the authentication could be relayed, why the account could reach the data, why detection took hours and whether the retained information was necessary.

A mature outcome includes revoked access, trusted devices, validated logs, notification decisions, restored service and tracked improvements. Possible actions include phishing-resistant authentication, tighter permissions, safer supplier workflows, improved detection, reduced retention and a rehearsed cloud containment process. The incident crosses every field, but the distinct lenses prevent important questions from disappearing.

12.7 What the scenario proves

No single control guarantees prevention. Effectiveness emerges from a system of barriers and recovery. If the message is blocked, harm is avoided. If the employee reports quickly, response begins earlier. If the credential cannot satisfy phishing-resistant authentication, access fails. If privilege is limited, consequence shrinks. If monitoring detects unusual activity, dwell time falls. If information is minimised, fewer people are affected. Security is therefore cumulative and socio-technical.

13. Discussion

The evidence supports a conditional answer and clarifies where contemporary practice succeeds or fails.

13.1 Is cybersecurity secure?

Cybersecurity is not itself an object that can be certified as permanently secure. It is a discipline for managing digital risk. Asking whether it is 'secure' confuses method with outcome. The stronger question is whether the discipline offers practices capable of reducing unacceptable harm in real environments. The evidence supports that capability. Authentication, least privilege, secure design, vulnerability management, monitoring, response and recovery each address known paths to harm, while governance connects them to organisational purpose.

However, capability does not guarantee implementation. Current UK evidence shows that many organisations lack structured risk assessment and formal response planning. Threat activity and nationally significant incidents remain serious. Cybersecurity therefore provides effective security only where controls are selected for context, maintained, tested and supported by accountable leadership.

13.2 What the field distinctions contribute

Separating computer, IT, information and cybersecurity improves analysis. Computer security prevents the individual system from becoming a black box. IT security addresses the estate and operational service. Information security protects meaning, obligations and lifecycle. Cybersecurity connects adversarial digital activity to wider harm. The distinctions are not competing definitions; they are complementary starting points.

The model also exposes gaps. A vulnerability can be technically fixed while unnecessary information remains. A policy can be compliant while devices are unmanaged. A SOC can detect activity but lack authority to isolate a business service. Clear roles and handoffs ensure that evidence reaches the person able to decide.

13.3 People and technology

The investigation rejects both technological determinism and user blame. Tools change exposure but inherit design assumptions. People make mistakes but also detect anomalies, report context and exercise ethical judgement. Automation is necessary for scale, while accountable human oversight is necessary for consequence. Effective security designs for this partnership.

13.4 Prevention and resilience

The most important change in the understanding of security is the move from perfect prevention to resilience. Prevention remains valuable; accepting that incidents can occur is not permission for weak controls. It is recognition that complex systems need detection, containment and trusted recovery. An organisation able to restore essential service and learn from failure is more secure than one whose only claim is that no incident has yet been observed.

13.5 Product and policy implications

Responsibility should move towards actors able to reduce risk efficiently. Manufacturers should provide secure defaults and updates. Service providers should expose usable evidence. Organisations should make ownership explicit and test response. Government should establish proportionate baselines and support smaller organisations. Users should receive understandable controls and recovery, not an endless transfer of responsibility.

This principle also explains the practical direction of device-comparison and provisioning tools. Advice becomes valuable when it helps a person compare support, understand risk, configure securely and record a decision. The aim is not to certify perfect safety but to turn evidence into the next safer action.

13.6 Further research

Future research should test the four-field model with practitioners and smaller organisations, examine whether clearer handoffs improve incident outcomes, and evaluate how security evidence can be presented to non-specialist decision makers. Longitudinal work is needed to determine whether product-security regulation changes update support and vulnerability handling in practice. AI-assisted security tools also require empirical evaluation of accuracy, operator trust, auditability and failure.

14. Conclusion

This dissertation asked whether contemporary cybersecurity can provide effective security for modern digital life and how four overlapping fields combine to produce that protection. The answer begins with a correction: security is not a permanent guarantee and cybersecurity is not an object that can be labelled secure or insecure. Security is the justified, continuously reviewed reduction of unacceptable harm. It requires prevention, detection, containment and recovery.

Computer security protects the individual system; IT security protects the organisational technology estate;

information security protects information and obligations across all formats; cybersecurity addresses harm through interconnected digital systems and its wider consequences. Their boundaries overlap because incidents cross them. The value of the distinctions lies in clearer questions, expertise, evidence and accountability.

Current evidence demonstrates serious pressure. Breaches and attacks are widely identified, nationally significant incidents have increased and many organisations lack risk assessment or formal response plans. Yet these facts do not show that cybersecurity is inherently ineffective. Established controls change attacker cost, reduce privilege, expose malicious activity and support recovery. The central weakness is uneven adoption and maintenance.

Technology alone is insufficient. Security depends on design, usable defaults, informed people, responsible leadership, lawful processing, supplier behaviour and tested recovery. AI and automation can extend defensive capacity but do not own risk or consequence. Education helps people participate, but must not be used to excuse unsafe products or fragile architecture.

The final answer is therefore conditional but positive. Contemporary cybersecurity can provide effective security when it is treated as a continuous socio-technical capability: governed as risk, engineered into systems, measured through evidence, designed for real users and prepared for failure. It cannot keep pace when reduced to a purchased tool, an annual exercise or a demand that individuals never make mistakes. The most credible security does not promise that nothing will happen. It demonstrates that avoidable harm is made less likely, important change is discovered, failure is contained and trusted operation can return.

References

- Adams, A. and Sasse, M.A. (1999). [Users are not the enemy. Communications of the ACM, 42\(12\), 40-46.](#)
- CISA (2023). [Shifting the Balance of Cybersecurity Risk: Principles and Approaches for Security-by-Design and -Default.](#)
- CISA and FBI (2025). [Product Security Bad Practices: updated guidance.](#)
- Department for Science, Innovation and Technology (DSIT) (2024). [The UK Product Security and Telecommunications Infrastructure product-security regime.](#)
- DSIT and Home Office (2026). [Cyber Security Breaches Survey 2025/2026.](#)
- DSIT and NCSC (2025). [Cyber Governance Code of Practice.](#)
- European Union Agency for Cybersecurity (ENISA) (2025). [ENISA Threat Landscape 2025.](#)
- Herley, C. (2009). [So Long, and No Thanks for the Externalities: The Rational Rejection of Security Advice by Users.](#)
- Kissel, R. et al. (2013). [NISTIR 7298 Revision 2: Glossary of Key Information Security Terms.](#)
- NCSC (2018). [Secure by Default.](#)
- NCSC (2023). [Cyber security design principles.](#)
- NCSC (2025a). [Annual Review 2025: Incident management.](#)
- NCSC (2025b). [Software Security Code of Practice: secure design and development.](#)
- NIST (2020). [SP 800-207: Zero Trust Architecture.](#)
- NIST (2023). [Artificial Intelligence Risk Management Framework \(AI RMF 1.0\).](#)
- NIST (2024a). [The NIST Cybersecurity Framework \(CSF\) 2.0.](#)
- NIST (2024b). [Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile.](#)
- NIST (2026). [NICE Framework Components, version 2.2.0.](#)
- Petersen, R. et al. (2020). [NIST SP 800-181 Rev. 1: Workforce Framework for Cybersecurity \(NICE Framework\).](#)
- Sasse, M.A., Brostoff, S. and Weirich, D. (2001). [Transforming the 'weakest link': a human/computer interaction approach to usable and effective security.](#)
- UK Parliament (2018). [Data Protection Act 2018.](#)
- UK Parliament (2022). [Product Security and Telecommunications Infrastructure Act 2022.](#)
- Verizon (2025). [2025 Data Breach Investigations Report.](#)
- von Solms, R. and van Niekerk, J. (2013). [From information security to cyber security. Computers & Security, 38, 97-102.](#)
- World Economic Forum (2025). [Global Cybersecurity Outlook 2025.](#)

All web sources were last checked on 19 July 2026. Statistical figures should be refreshed before any later formal submission.

Appendix A. Field comparison

COMPUTER SECURITY

Protected object: an individual computing system and locally processed data. Core evidence: trusted build, hardened configuration, endpoint telemetry, vulnerability and malware analysis. Representative roles: endpoint or platform security engineer, operating-system specialist, malware analyst, vulnerability researcher.

IT SECURITY

Protected object: an organisation's technology estate and operational services. Core evidence: inventory, identity records, configuration baselines, monitoring, access reviews, patch and recovery tests. Representative roles: identity specialist, network or cloud security engineer, security administrator, SOC analyst, vulnerability manager.

INFORMATION SECURITY

Protected object: information in any form and the obligations attached to it. Core evidence: classification, risk assessment, policy, assurance, supplier review, retention and continuity decisions. Representative roles: information-security manager, risk analyst, security architect, auditor, information owner.

CYBERSECURITY

Protected object: people, organisations, services and infrastructure exposed to harm through interconnected digital systems. Core evidence: threat assessment, incident timeline, attack-path findings, containment and lessons learned. Representative roles: incident responder, threat hunter, intelligence analyst, penetration tester, forensics specialist, OT cybersecurity engineer.

7. Response: Are roles, permissions, communications and legal routes rehearsed?
8. Recovery: Can trusted operation and necessary information be restored within agreed objectives?
9. Usability and ethics: Can people use the control, and is it lawful, necessary and proportionate?
10. Learning: Are incidents, exercises and control failures converted into owned improvements?

Appendix C. Relationship to the original project

The 2020 A-level EPQ established the enduring starting question: why does cybersecurity appear unable to provide complete protection, and what part do people, education and automation play? The present dissertation is not an edited copy or annotated commentary. It replaces the original structure, removes the unsupported questionnaire claims, uses a new research method, introduces explicit field boundaries and evaluates evidence available in 2026. The original submission remains archived so the development of the research can be examined transparently.

Appendix B. Security effectiveness test

1. Purpose: What valued asset, service, person or right is being protected?
2. Threat: Which plausible actor, event or failure could cause unacceptable harm?
3. Ownership: Who has authority to decide and who operates the relevant control?
4. Prevention: Which controls reduce likelihood and how is their coverage demonstrated?
5. Detection: Which evidence would reveal harmful change and who reviews it?
6. Containment: What limits the scope of a compromised device, identity or supplier?